

Organization: Exam

- We will provide a set of open questions (similar to RWC)
- Next days:
 - Wednesday: Test exam
 - Monday: Q/A session
 - Wednesday: no exercise

Web Attacks beyond the Lecture Scope

Web Security
Juraj Somorovsky

Summer Semester 2024
Paderborn University

Overview

1. Web technologies
2. Web attacks
3. XML and Single Sign-On (SAML)
4. JSON and OIDC / OAuth
5. REST

Today

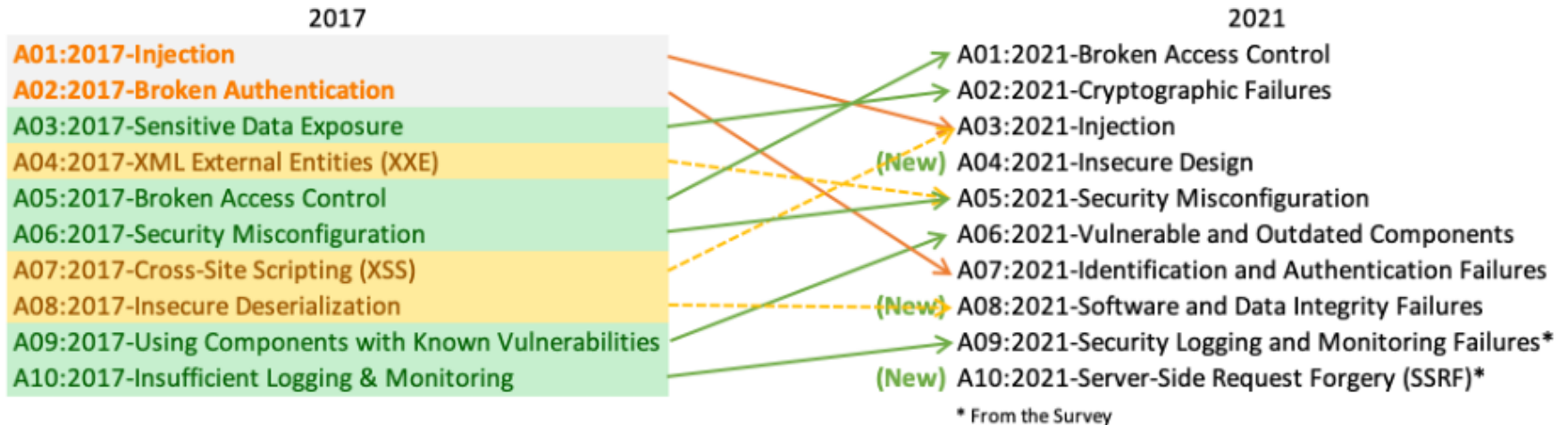
- OWASP Top 10
- Real-life security incidents
- Our research
- No recording ...

Open Web Application Security Project (OWASP)

- Organizes conferences, workshops
- Provides cheat-sheets, tools, standards, ...
- Security publications
- Projects:
 - Juice shop
 - ModSecurity Rule Sets
 - Zed Attack Proxy (ZAP)
 - Top 10

OWASP Top 10

- Summarizes top risks based on
 - Recent vulnerabilities
 - Community polls



A01:2021-Broken Access Control

- Problems
 - Unauthorized disclosure of information
 - Modification or deletion of all data
 - Execution of a function outside the specified permissions
- Typical errors
 - Least privilege principle violated
 - Bypassing access controls by changing the URL
 - Access to API with incorrect or missing access control
 - CORS misconfiguration

A01:2021-Broken Access Control

Real example:



- USPS introduced a service for tracking information in 2017
- Account required to gain access (authentication)
- No authorization was performed after a login

„U.S. Postal Service just fixed a security weakness that allowed anyone who has an account at usps.com to view account details for some 60 million other users, and in some cases to modify account details on their behalf.“

A02:2021-Cryptographic Failures

- Attacks on confidentiality/authenticity/integrity
- Examples:
 - Missing crypto (e.g., data stored in cleartext)
 - Broken crypto
 - Weak crypto algorithms (DES, MD5, SHA1)
 - Weak entropy by generating random numbers

A02:2021-Cryptographic Failures

Real Example: **facebook**

- Facebook Security Engineer noticed in 2019 that passwords are written as plaintext in log files
- 200 - 600 million Facebook users affected
- Logs with passwords could be traced back to 2012
- Over 20,000 Facebook employees had access to the logs

A02:2021-Cryptographic Failures

Real Example

CVE-2020-7010 Detail

Description

Elastic Cloud on Kubernetes (ECK) versions prior to 1.1.0 generate passwords using a weak random number generator. If an attacker is able to determine when the current Elastic Stack cluster was deployed they may be able to more easily brute force the Elasticsearch credentials generated by ECK.

Metrics

CVSS Version 4.0

CVSS Version 3.x

CVSS Version 2.0

NVD enrichment efforts reference publicly available information to associate vector strings. CVSS information contributed by other sources is also displayed.

CVSS 3.x Severity and Vector Strings:



NIST: NVD

Base Score: 7.5 HIGH

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N

A03:2021-Injection

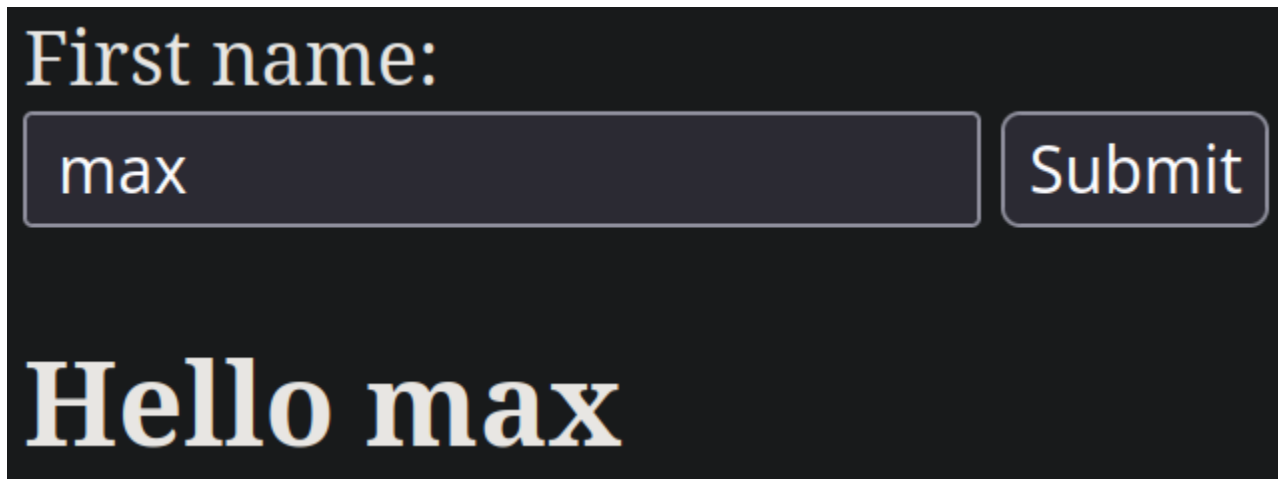
- Examples?

A03:2021-Injection

- XSS
- SQL injection
- XML injection
- Template injection

A03:2021-Injection

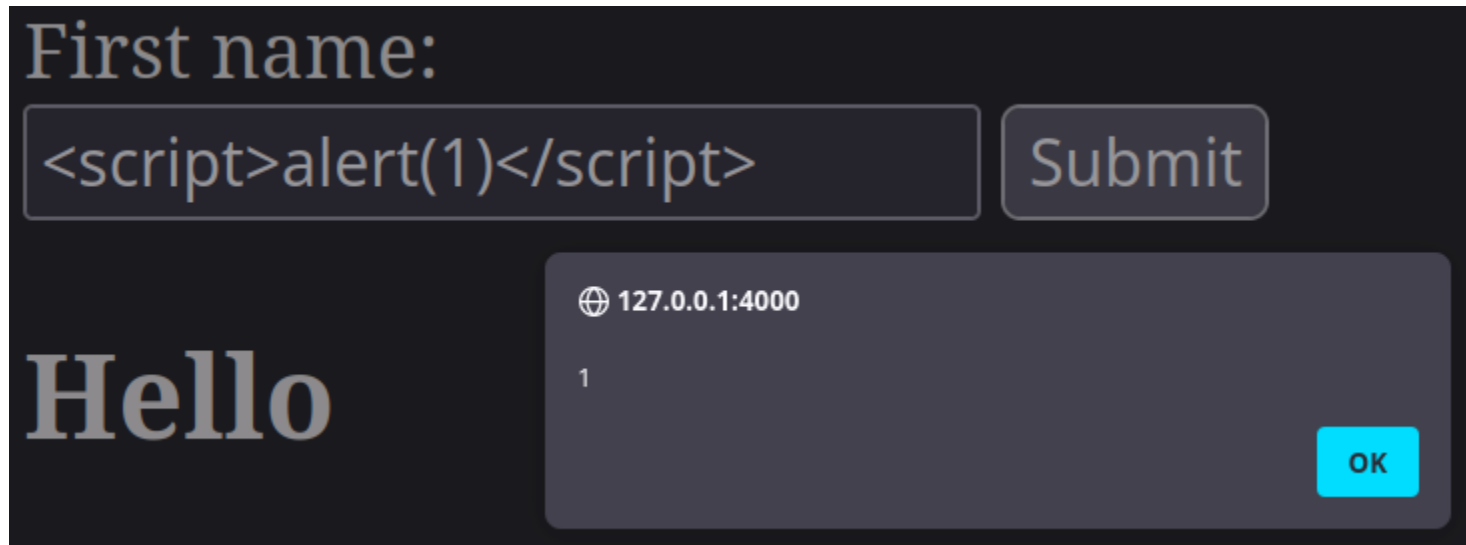
- What could be the danger here?



The image shows a dark-themed web interface. At the top, the text "First name:" is displayed in a light blue serif font. Below it is a dark grey input field containing the text "max" in a light blue sans-serif font. To the right of the input field is a rounded rectangular button with the text "Submit" in a light blue serif font. Below the input field and button, the text "Hello max" is displayed in a large, bold, light blue serif font.

A03:2021-Injection

- Of course ...



A03:2021-Injection

Template Injection

- What if I told you we can do RCE

First name:

```
obals__['os'].popen('ls').read()}}
```

Submit

Hello uid=0(root) gid=0(root) groups=0(root) !

- With the help of Python os module
- Vector:

```
{{config.__class__.__init__.__globals__['os'].popen('id').read()}}
```

Source: Maximilian Hildebrand: Improving the Detection and Identification of Template Engines for Large-Scale Template Injection Scanning

A03:2021-Injection

Template Injection

- Reason: Templating with context ~ Prepared statements

```
1  # unsicherer Code
2  templateString = '<h2>Hello {}!</h2>'.format(user_input)
3  return render_template_string(templateString)
4
```

A03:2021-Injection

Template Injection

- Reason: Templating with context ~ Prepared statements

```
1  # unsicherer Code
2  templateString = '<h2>Hello {}!</h2>'.format(user_input)
3  return render_template_string(templateString)
4
5  # wenn user_input der RCE Payload ist, steht dort effektiv:
6  templateString = '<h2>Hello {{ config.__class__.__init__.__globals__["os"].popen("ls").read() }}!</h2>'
7  return render_template_string(templateString)
8
9  # sicherer Code
10 templateString = '<h2>Hello{{ foo }}!</h2>'
11 return render_template_string(templateString, foo=user_input)
```

A03:2021-Injection

Template Injection

- CVEs:
 - 2022: 25
 - 2021: 27
 - 2020: 24
 - 2019: 14
 - 2018: 7
 - 2017: 3
 - 2016: 0
 - 2015: 2
- Total: 103, mostly RCE
- Easily exploitable
- Mostly no privileges required

A03:2021-Injection

Template Injection

- Template engines:
 - Provide placeholders, dynamically replaced with calculations `{{7*7}}` or database data `{{username}}`
 - Reusability
 - Separation of representation and business logic
 - But also: loops, conditions, r/w files, code execution...
 - Dangerous if user input is inserted unvalidated
- Examples:
 - Mustache
 - Handlebars

A04:2021-Insecure Design

- Category for risks due to design and architecture errors
- Independent of the implementation
- Selection of typical errors:
 - Lack of security awareness in development (lifecycle)
 - Use of insecure / outdated concepts
 - Reliance on client-side checks
 - Lack of enforcement of all steps in the business logic

A04:2021-Insecure Design

Real Example: Weak Security Questions

[Search jobs](#) [Sign in](#) [Search](#) [International edition](#)

The Guardian

News website of the year

[News](#) [Opinion](#) [Sport](#) [Culture](#) [Lifestyle](#) [More](#)

[US](#) [World](#) [Environment](#) [Soccer](#) [US Politics](#) [Business](#) [Tech](#) [Science](#) [Newsletters](#) [Fight to vote](#)

Sarah Palin

● This article is more than 12 years old

Sarah Palin tells court that email hacker disrupted campaign and personal life

Former economics student David Kernell faces up to 50 years in jail if convicted of hacking into email account

Sarah Palin today addressed the jury at the criminal trial of the man accused of hacking into her email account during the 2008 presidential election campaign.

Palin spent 45 minutes in the witness box in a federal court in Knoxville, Tennessee where David Kernell, 22, faces up to 50 years in prison if found guilty of four charges.

Palin told the court that the "disturbance" to her email had disrupted her personal and political life. "If the intent was to disrupt it, it was successful. It caused a huge disruption in the campaign," she said.

The prosecution alleges that Kernell, then an economics student at the University of Tennessee-Knoxville, broke into Palin's Yahoo! email account gov.palin in September 2008 by answering simple security questions. He gained the information from Google, including her date of birth, the postcode of her home, and where she had met her husband, Todd. He is accused of changing her password to "popcorn" and posting some of her email contents on the internet under the pseudonym "rubico".

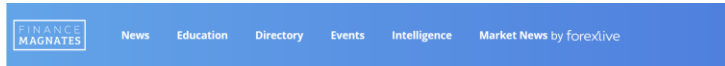
Ed Pilkington in New York

@edpilkington

Fri 23 Apr 2010 23.32 BST

A04:2021-Insecure Design

Real Example: Client-side Validation



FM Home > Cryptocurrency > News > \$170 Million Mistake: BitGrail May Have Been Aware of Bug that Led to Hack

\$170 Million Mistake: BitGrail May Have Been Aware of Bug that Led to Hack

Some evidence suggests that BitGrail may have tried to solve the bug on its own as early as December.

Wednesday, 14/02/2018 | 10:28 GMT+2 by Rachel McIntosh

News Bitcoin Scam



The Hack

On Friday, February 16, the Italian crypto exchange known as 'BitGrail' posted a notice addressed to all users informing them that hackers had infiltrated the exchange and walked away with 17 million Nano tokens (XRB) in hand.

Since late November, the price of XRB has soared from around \$0.20 to its valuation of nearly \$10 last week (down from its height of over \$30 in early January), making the stolen tokens worth approximately \$170 million at the time of the hack.

[...]

"As far as I understand, Bitgrail had issues with validating users' balances and allowing insufficient withdrawals [from] the system. Some users in the community and security researchers claim that Bitgrail had two main vulnerabilities.

The first one was a client-side bad practice and vulnerability which allowed the hacker to bypass the javascript validation code locally, and trick the exchange to let the client withdraw more fund than the hacker owns. The second one reported was a permission bug where one user can request a withdraw to his [wallet address](#) but use another account balance which ended in a [Negative Balance](#) on the victim account."

Essentially, it seems that at least one user who was using BitGrail for arbitrage trading discovered at some point that it was possible to run BitGrail's javascript manually to withdraw a greater amount of XRB than what was in any given user's balance.

Priel added that BitGrail could have discovered problems within its security system if it had been more proactive about testing its systems for flaws: "From my point of view, it doesn't look like BitGrail implemented [sufficient security](#) layers. And if they were they could stop such vulnerabilities by initiating penetration tests and code reviews, monitoring of abnormal activity in the system, rate limiting on large withdraw requests and much more"

A05:2021-Security

Misconfiguration

- Collective category for insecure (default) configurations
- Enables further attacks
- Examples:
 - Detailed error messages
 - Missing security headers (e.g. protection against "clickjacking")
 - Insecurely configured web caches, cloud storages, ...
 - Non-validated redirects ("open redirect")
 - Insecurely configured parsers (XXE)

A05:2021-Security Misconfiguration

Real Example: Insecure Cloud Storage

More than 540 million records of Facebook users were exposed by publicly accessible Amazon S3 buckets used by two third-party apps to store user data such as plain text app passwords, account names, user IDs, interests, relationship status, and more.

As discovered by the UpGuard Cyber Risk team, Mexico-based media company [Cultura Colectiva](#) stored the records of roughly 540 million of its users within a 146 GB database called "cc-datalake," stored in a misconfigured Amazon S3 bucket which gave anyone download permissions.

This huge collection of Facebook records contained "comments, likes, reactions, account names, FB IDs and more," allowing Cultura Colectiva to "to tune an algorithm for predicting which future content will generate the most traffic."

[540 Million Facebook Records Leaked by Public Amazon S3 Buckets \(bleepingcomputer.com\)](https://bleepingcomputer.com/news/security/540-million-facebook-records-leaked-by-public-amazon-s3-buckets/)



A06:2021-Vulnerable and Outdated Components

- Usage of outdated frameworks, libraries, software packages, ...which are vulnerable to known attacks

A06:2021-Vulnerable and Outdated Components



Search blog

[← Blog Home](#)

Qualys Study Reveals How Enterprises Responded to Log4Shell



Mehul Revankar, Vice President of Product Management, Qualys
March 18, 2022 - 6 min read

On December 9, 2021, a critical zero-day vulnerability affecting Apache's Log4j2 library, a Java-based logging utility, was disclosed to the world.

[...]

It didn't take very long for this critical Java vulnerability to be exploited in the wild. Nearly 1 million attack attempts were launched in just 72 hours following the Log4Shell vulnerability's disclosure.

There was no time to waste. The bad guys didn't care that it was the holiday season. [...]

30%

of Log4Shell instances
remain vulnerable

Log4Shell Exposure

- [...]
- More than two months later, 30% of Log4j instances remain vulnerable for exploit.^[1]

Log4Shell Threat Landscape

- [...]
- Surprisingly, more than 50% of application installations with Log4j were flagged as "end-of-support". This means that these publishers will likely NOT be providing Log4Shell security patches for these apps.



OVER
50%

of application installations with Log4j2 were flagged as **"end of support"**

A07:2021-Identification and Authentication Failures

- Error or insufficient verification during user authentication
- Insecure session management
- Examples:
 - Lack of protection against credential stuffing (brute force attacks with known credentials)
 - Weaknesses in the implementation of single sign-on
 - Insecure password policies
 - Insecure storage of passwords

A08:2021-Software and Data Integrity Failures

- Lack of integrity protection: Manipulations remain undetected
 - Modification of processed / stored data
 - Replacement of software with infected versions / updates
- Examples:
 - Updates without signature: Manipulated update infects system

A08:2021-Software and Data Integrity Failures

SOLARWINDS-HACK

Massiver Cyberangriff gefährdet deutsche Behörden

VON BASTIAN BENRATH · AKTUALISIERT AM 07.01.2023 · 16:46



Eine gravierende Cyberattacke hat Hackern Zugriff auf mehr als 250 amerikanische Behörden und Unternehmen verschafft. Nun wird klar: Auch zahlreiche deutsche Behörden haben die kompromittierte Software eingesetzt.

[...]

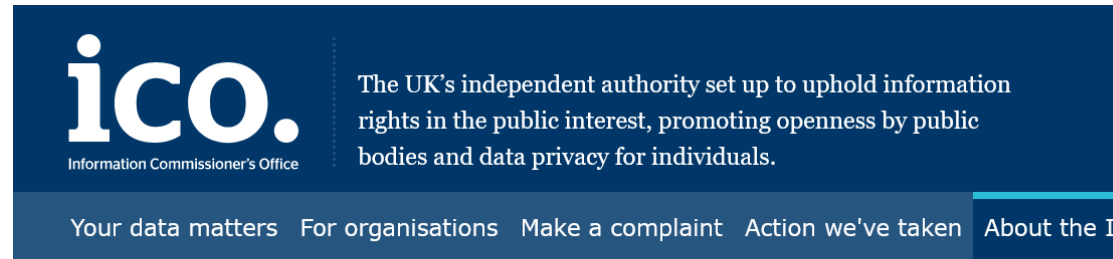
Nicht nur das schiere Ausmaß der Attacke ist bestürzend: Den Hackern gelang es, eine Hintertür in die Updates von Solarwinds verbreiteter Netzwerksoftware „Orion“ einzubauen. Durch die automatisch heruntergeladenen Aktualisierungen erhielten sie so Zugriff auf insgesamt rund 18.000 Netzwerke von Unternehmen und Regierungsbehörden. Vor allem aber geschah das schon mindestens im Frühling vergangenen Jahres. Die Hacker hatten so rund neun Monate Zeit, sich ungestört in den Systemen umzuschauen und mutmaßlich geheime Daten mitzulesen und abzuschöpfen. Unter anderem gelang es ihnen, bei Microsoft bis zu den streng geschützten Quellcodes der Programme des Softwarekonzerns vorzudringen.

A09:2021-Security Logging and Monitoring Failures

- Insufficient logging and monitoring
 - Attacks remain undetected and cannot be stopped promptly
 - Attacks can be expanded
 - Extent of a detected attack unclear

A09:2021-Security Logging and Monitoring Failures

Real Example: British Airways



[About the ICO](#) / [Media centre](#) / [News and blogs](#) /

ICO fines British Airways £20m for data breach affecting more than 400,000 customers

ICO fines British Airways £20m for data breach affecting more than 400,000 customers

Date **16 October 2020**

Type **News**

The Information Commissioner's Office (ICO) has [fined British Airways \(BA\) £20m for failing to protect the personal and financial details of more than 400,000 of its customers.](#)

An ICO investigation found the airline was processing a significant amount of personal data without adequate security measures in place. This failure broke data protection law and, subsequently, BA was the subject of a cyber-attack during 2018, which it did not detect for more than two months.

A10:2021 – Server-Side Request Forgery (SSRF)

Real Example: Financial Transactions



API Threat Research: Server-side Request Forgery on FinTech Platform Enabled Administrative Account Takeover



Salt Labs

Apr 7, 2022

Incident Synopsis

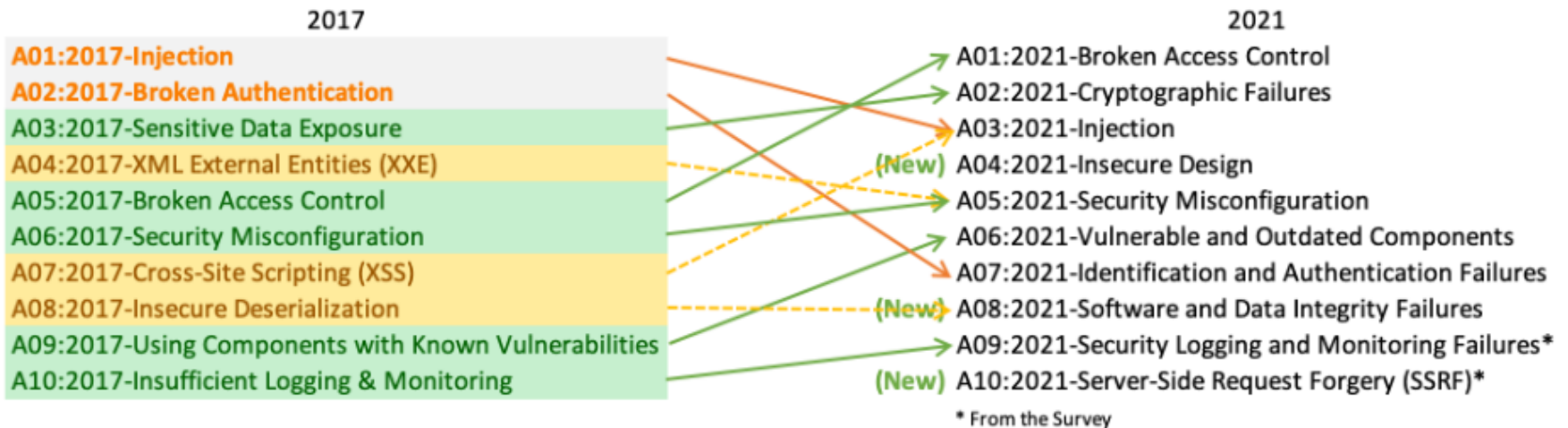
The Salt Labs team helps customers and prospects discover vulnerabilities in their APIs. In this case, we investigated the platforms of a large US-based FinTech company. This company offers a “digital transformation” service for banks of all sizes, allowing them to switch many of their traditional banking services to online services. The platform is already actively integrated into many banks’ systems, and its services are being used daily by millions of people.

As a result of API vulnerabilities that our researchers identified, they were able to launch attacks where:

- Attackers could gain administrative access to the banking system using this platform
- Attackers could leak users’ personal data
- Attackers could access users’ banking details and financial transactions
- Attackers could perform unauthorized funds transfers into their own bank accounts

[Salt Labs API Threat Research](#)

Questions



Acknowledgements

- Slides partially created by Karsten Meyer zu Selhausen
- Tessa pictures by https://www.fiverr.com/tnhs_project

